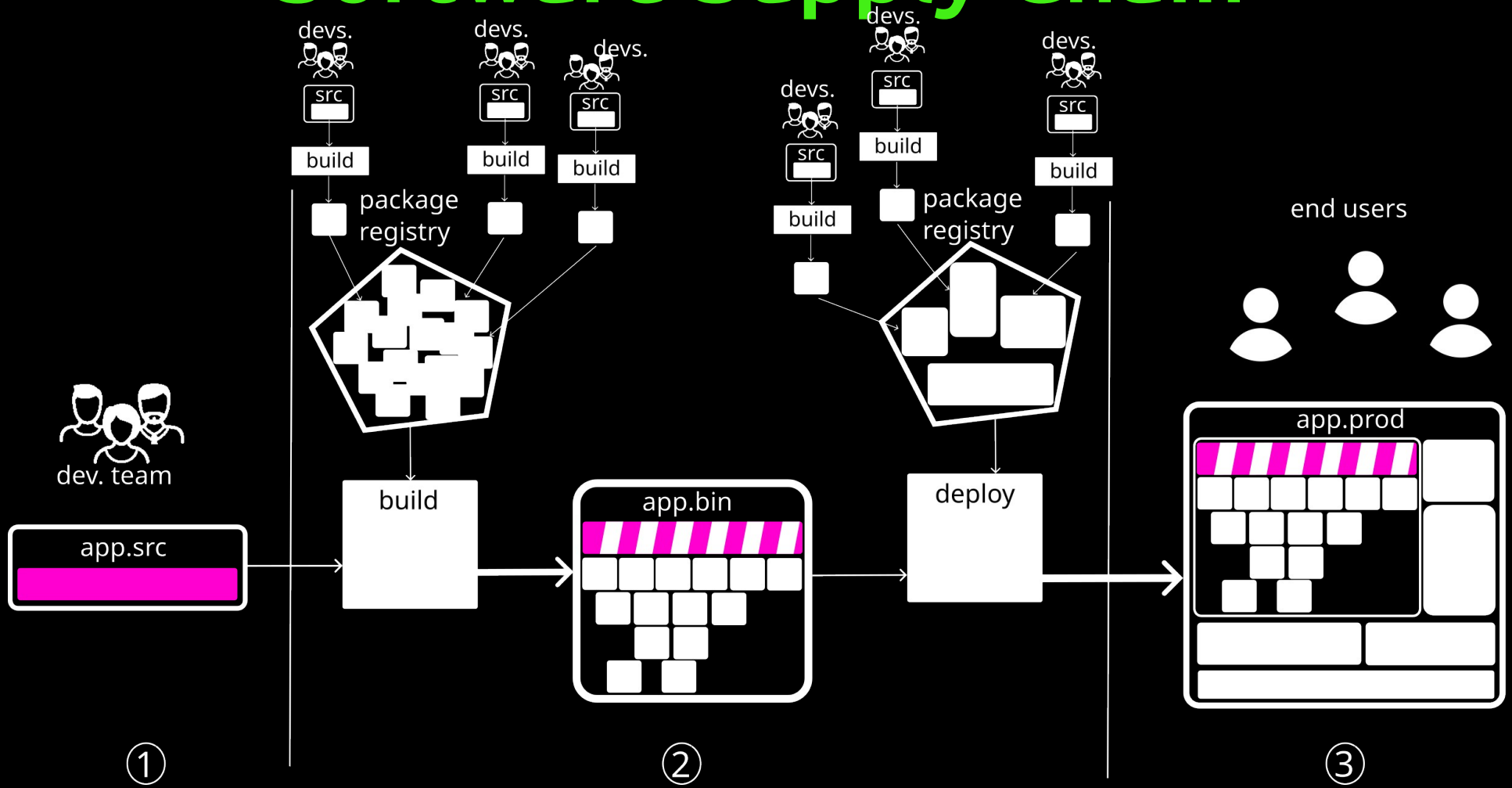


Punking Up Dependency Hell

Benoit Baudry
Université de Montréal



Software Supply Chain



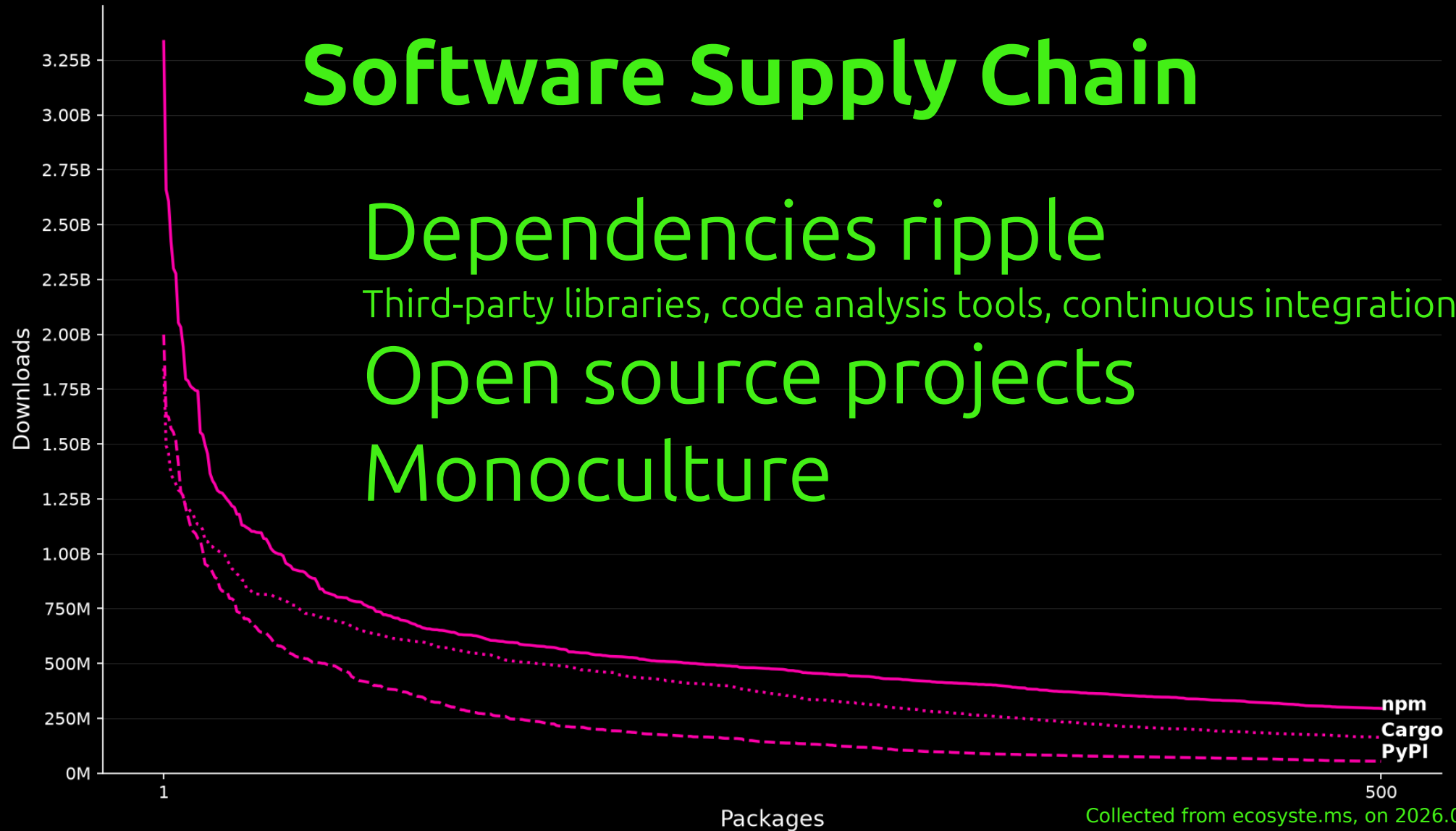
Software Supply Chain

Dependencies ripple

Third-party libraries, code analysis tools, continuous integration

Open source projects

Monoculture



Security

- Trusting trust
 - Trojan in compiler
 - Malicious CI, e.g. Solarwinds
- Tampering with reusable components
 - Third-party libraries, e.g. Codecov, log4J, event-stream, xz
 - Github actions, e.g., tj-action
 - Typosquatting, e.g., Python packages, Minecraft mods
- AI amplification
 - Larger software supply chain (pre-trained models, agents, etc.)
 - Reduce time to exploitation
 - Agents operate with high privileges that can be exploited

Thompson, Ken. "Reflections on trusting trust." Communications of the ACM 1984.

Ladisa, Piergiorgio, et al. "Sok: Taxonomy of attacks on open-source software supply chains." IEEE S&P 2023.

Neupane, Shradha, et al. "Beyond typosquatting: an in-depth look at package confusion." USENIX security 2023.

Williams, Laurie, et al. "Research directions in software supply chain security." ACM TOSEM 2025.

Fares, Madjda, Yogya Gamage, and Benoit Baudry. "Unpacking Security Scanners for GitHub Actions Workflows." arXiv 2026.

Reliability

- **Conflicting dependencies**
 - Black-box resolution algorithms
 - Pinning vs. floating
- **Breaking dependencies**
 - Incorrect dependencies
 - Breaking updates

Wang, Ying, et al. "Will dependency conflicts affect my program's semantics?." IEEE TSE 2021

Venturini, Daniel, et al. "I depended on you and you broke me: An empirical study of manifesting breaking changes in client packages." ACM TOSEM 2023.

Jayasuriya, Dhanushka, et al. "Understanding the impact of APIs behavioral breaking changes on client applications." FSE 2024.

Human aspects

- Pressure on OSS developers
 - OSS developers quit and remove, e.g., left-pad
 - OSS developers pressured to accept changes, e.g., xz
- Political activism
 - OSS developers protest through their packages

Addressing Reliability

- Compatibility testing
 - Target test generation on client – library usages
 - Benchmark library updates with a pool of clients
 - Dependency graph analysis for remediation
- Fixing breaking updates
 - Diff on dependency versions
 - Client code analysis
 - Patch generation
 - Update transformation generation

Chen, Lingchao, et al. "Taming behavioral backward incompatibilities via cross-project testing and analysis." ICSE 2020.

Zhang, Lyuye, et al. "Compatible remediation on vulnerabilities from third-party libraries for java projects." ICSE 2023.

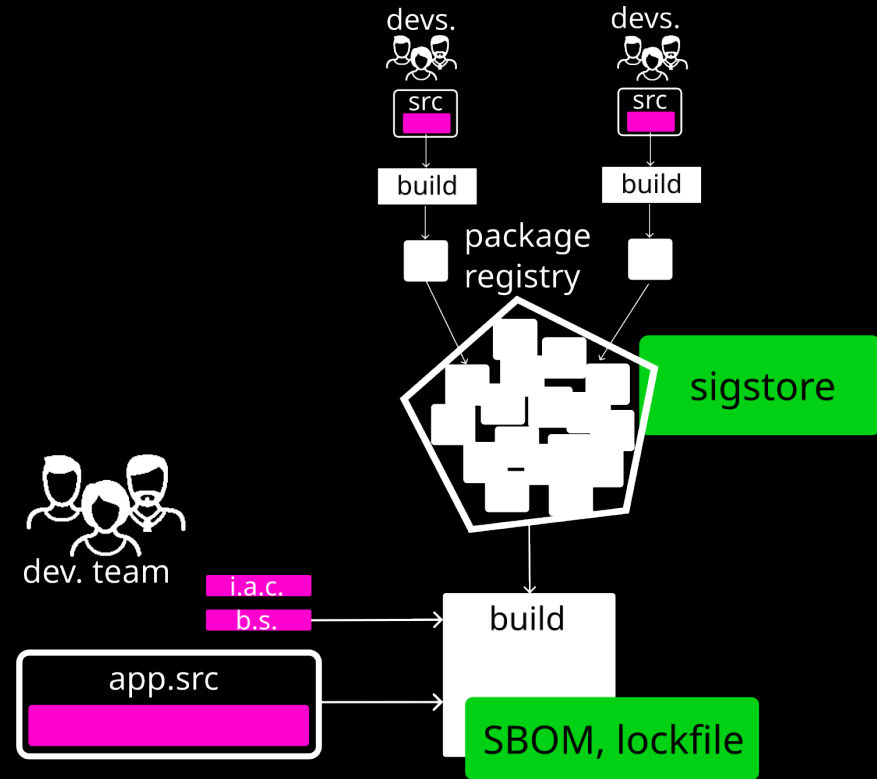
Zhong, Hao, and Na Meng. "Compiler-directed migrating API callsite of client code." ICSE 2024.

Frintke, Lukas, and Jens Krinke. "Automatically fixing dependency breaking changes." FSE 2025.

Reyes, Frank, et al. "Byam: Fixing breaking dependency updates with large language models." EMSE 2026.

Addressing security

- Transparency
- Integrity
- Provenance
- Signing



Torres-Arias, Santiago, et al. "in-toto: Providing farm-to-table guarantees for bits and bytes." 28th USENIX Security Symposium (USENIX Security 19). 2019.

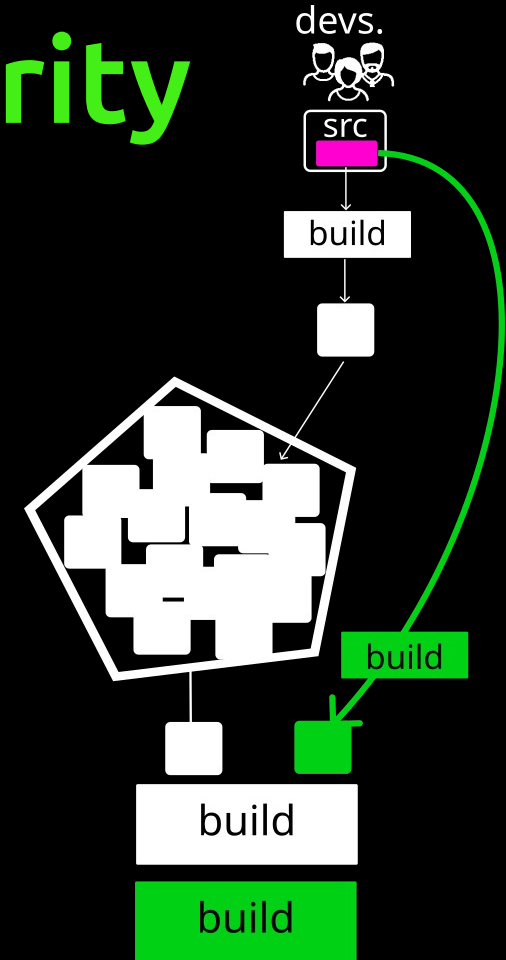
Schorlemmer, Taylor R., et al. "Signing in four public software package registries: Quantity, quality, and influencing factors." IEEE S&P 2024.

Mohayej, Hamid, et al. "Securing dependencies: A comprehensive study of Dependabot's impact on vulnerability mitigation." EMSE 2025.

Gamage, Yogya, et al. "The design space of lockfiles across package managers." EMSE 2026.

Addressing Security

- Reproducible builds
 - Concurrency
 - Environment specificities
- Canonicalization
- Diverse compilers



Wheeler, David A. "Countering trusting trust through diverse double-compiling." ACSAC 2005.

Lamb, Chris, and Stefano Zacchiroli. "Reproducible builds: Increasing the integrity of software supply chains." IEEE Software 2021.

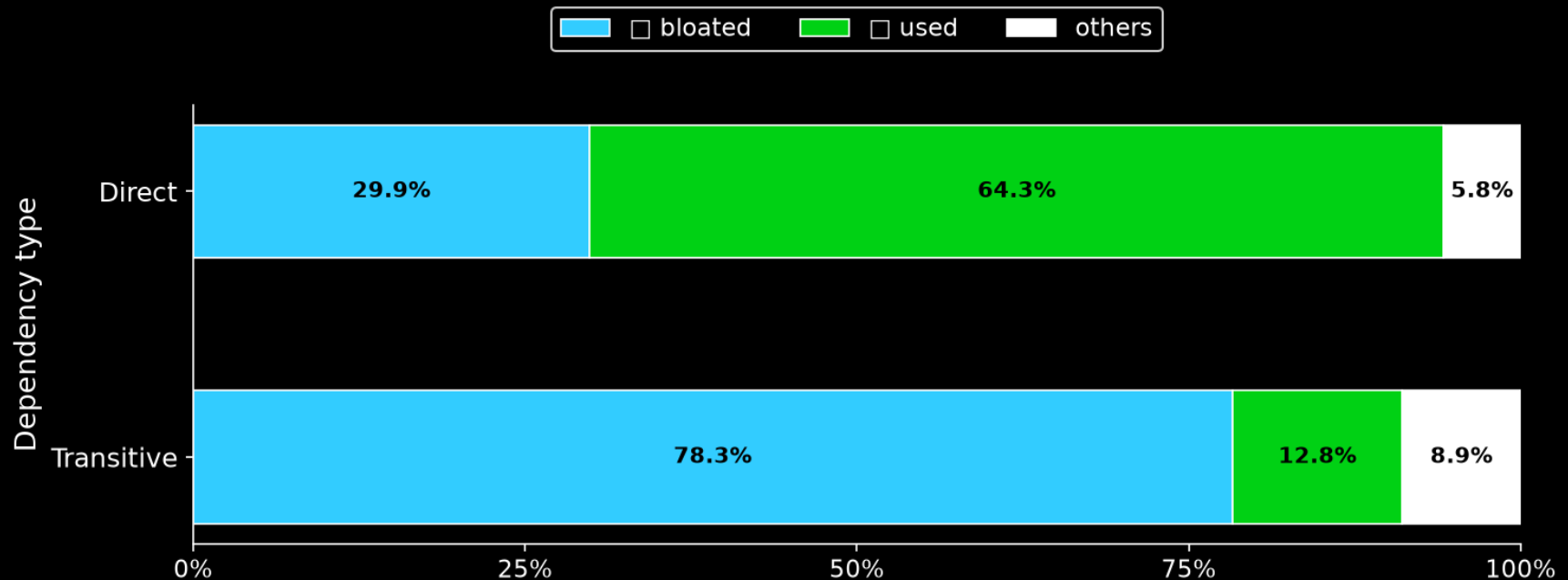
Fourné, Marcel, et al. "It's like flossing your teeth: On the importance and challenges of reproducible builds for software supply chain security." IEEE S&P 2023.

Dietrich, Jens, and Behnaz Hassanshahi. "DALEQ--Explainable Equivalence for Java Bytecode." ASE 2025.

Sharma, Aman, Benoit Baudry, and Martin Monperrus. "Causes and Canonicalization of Unreproducible Builds in Java." IEEE TSE 2025.

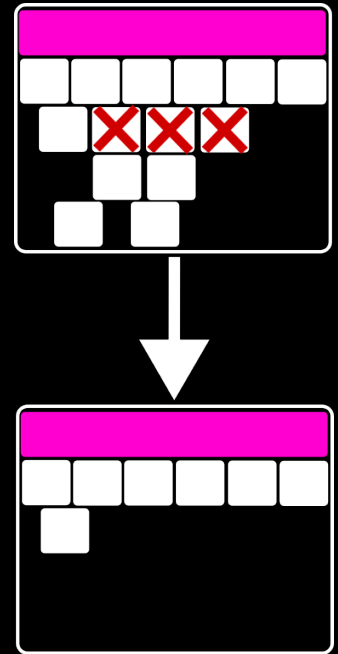
Oversized Supply Chain

- Package managers simplify reuse
- And we reuse too much



Dependency removal

- Analyze the client / library interactions
 - Statically or dynamically
 - Identify unused library
- Remove unused libraries
 - Rewrite the dependency file
 - Rewrite the binary



Bruce, Bobby R., et al. "Jshrink: In-depth investigation into debloating modern java applications." ESEC / FSE 2020.

Latendresse, Jasmine, et al. "Not all dependencies are equal: An empirical study on production dependencies in npm." ASE 2022.

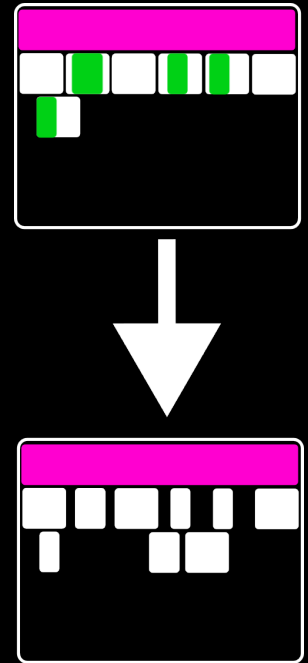
Song, Xiaohu, et al. "Efficiently trimming the fat: Streamlining software dependencies with java reflection and dependency analysis." ICSE 2024.

Drosos, Georgios-Petros, et al. "Bloat beneath python's scales: A fine-grained inter-project dependency analysis." FSE 2024.

Liu, Yuxin, et al. "Detecting and removing bloated dependencies in CommonJS packages." JSS 2025.

Dependency specialization

- Analyze the client / library interactions
 - Statically or dynamically
 - Identify unused library parts
- Remove unused parts
 - Mocks
 - Code Removal



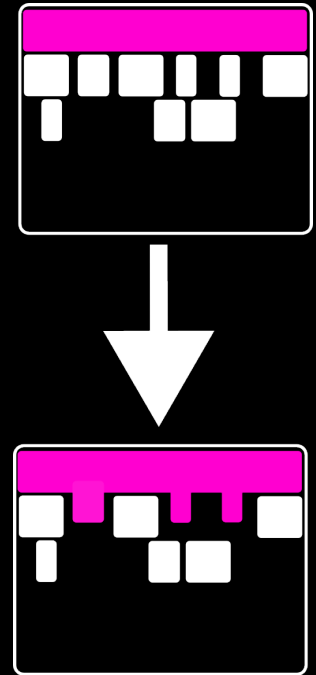
Mishra, Shachee, and Michalis Polychronakis. "Shredder: Breaking exploits through API specialization." ACSAC 2018.

Soto-Valero, César, et al. "Automatic specialization of third-party java dependencies." IEEE TSE 2023.

Han, Jiaxuan, et al. "δ-SCALPEL: Docker Image Slimming Based on Source Code Static Analysis." IEEE TSE 2025.

Dependency reduction

- Reduce necessary dependencies
- Regenerate
- Rewrite
- Transplant



Vasilakis, Nikos, et al. "Supply-chain vulnerability elimination via active learning and regeneration." CCS 2021.

Jaisri, Pongchai, Brittany Reid, and Raula Gaikovina Kula. "A Preliminary Study on Self-contained Libraries in the NPM Ecosystem." Book chapter 2025.

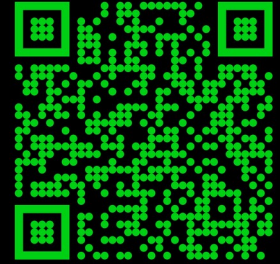
Liu, Yuxin, Cristian Bogdan, and Benoit Baudry. "A Longitudinal Study of Dependency Reclassifications in JavaScript Projects." 2026.

more to come this week

- Galápagos: Automated N-Version Programming with LLMs
- Causes and Canonicalization of Unreproducible Builds in Java
- Understanding the Limitations of C/C++ Binary Third-Party Library Detection Tool: An Empirical Study at Scale
- Pig: Leveraging Large Language Models for Python Library Migrations
- Package Dashboard: A Cross-Ecosystem Framework for Dual-Perspective Analysis of Software Packages
- CI/CD Configuration Practices in Open-Source Android Apps: An Empirical Study
- JDetect: A Fine-Grained Detecting Method for Java Source SCA by Fusing Behavioral and Code Features
- How Can ChatGPT Support Human Security Testers to Help Mitigate Supply Chain Attacks?
- Break to Adapt: Knowledge-Based Updates of Breaking Dependencies in JavaScript
- DependaFix: A GitHub App for Fixing Breaking Dependency Updates in CI Build for Java Projects
- An Empirical Analysis of Machine Learning Model and Dataset Documentation, Supply Chain, and Licensing Challenges on Hugging Face
- Towards Predicting Multi-Vulnerability Attack Chains in Software Supply Chains from Software Bill of Materials Graphs
- Uncovering Similar but Different Packages in PyPI and Potential Security Threats

| software°
performing
.:art:\+..
/research]
:.-krew:-:

Conclusion *



- Dependencies ripple across the supply chain
- Let's reconcile reuse and resilience
- Let's downsize dependency hell

Crew: Y. Gamage, M. Fares, N. Gonzalez, A. Nasirianfar, R. Mendieta, J. Ron, A. Sharma, F. Reyes, C. Soto-Valero, D. Tiwari, Y. Liu, T. Durieux, M. Monperrus

* "security teams do not consider rickrolling as malicious behavior". Ladisa et al. "Journey to the center of software supply chain attacks." IEEE S&P 21.6
Spracklen, Joseph, et al. "We have a package for you! a comprehensive analysis of package hallucinations by code generating LLMs." USENIX Security 2025
Carminé Cesarano, and Martin Monperrus. "The Grand Software Supply Chain of AI Systems". 2026